CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: BRabbit (CyberDefenders)

Análisis y reconstrucción del ransomware Bad Rabbit. Cubre vectores de Phishing, ingeniería inversa, secuestro del MBR y mapeo de amenazas (Sandworm) en MITRE ATT&CK.

Sebastian David
Torres Reyes

Escenario:

Eres un investigador asignado para ayudar a Drumbo, una empresa que recientemente fue víctima de un ataque de ransomware. El ataque comenzó cuando un empleado recibió un correo electrónico que parecía ser del jefe. Presentaba el logotipo de la empresa y una dirección de correo electrónico conocida. Creyendo que el correo era legítimo, el empleado abrió el archivo adjunto, lo que comprometió el sistema y activó el ransomware, cifrando archivos confidenciales. Tu tarea es investigar y analizar los artefactos para descubrir información sobre el atacante.

Herramientas utilizadas:

- VirusTotal
- Any.run
- Email Header Analyzer
- Tria.ge
- IDA
- Malpedia

Resumen:

El incidente analizado detalla una infección de ransomware Bad Rabbit, originada mediante un correo de phishing que empleó técnicas de suplantación visual (typosquatting) simulando ser el CEO. Tras evadir los análisis de sandbox y engañar al usuario para desactivar sus defensas, el código estableció persistencia mediante tareas programadas con altos privilegios y utilizó Mimikatz para extraer credenciales y apoyar el movimiento lateral del ransomware. El impacto final consistió en el secuestro de un driver legítimo (DiskCryptor) para cifrar el disco duro y modificar el MBR con fines de extorsión, manteniendo comunicación con infraestructura C2 externa (2.16.168.119:80, 52.123.128.14:80 y 20.190.160.65:80).

P1: El correo electrónico de phishing utilizado para enviar el archivo adjunto malicioso mostró varios indicadores de un posible intento de ingeniería social. Reconocer estos indicadores puede ayudar a identificar amenazas similares en el futuro.

¿Cuál es la dirección de correo electrónico sospechosa que envió el archivo adjunto?

R: theceojamessmith@Drurnbo.com

Para obtener una mejor perspectiva de los detalles del correo electrónico sospechoso se usó la herramienta en línea Email Header Analyzer. Se determinó que el atacante utilizó una técnica de Typosquiatting y que la dirección de correo electrónico del remitente fue theceojamessmith@Drurnbo.com.

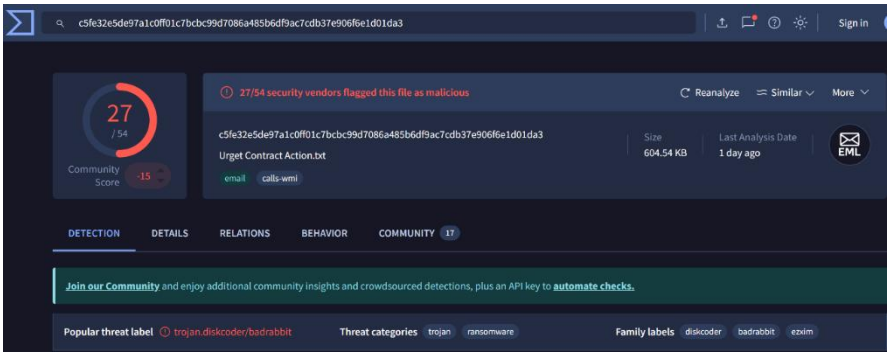
From	Drumbo® <theceojamessmith@Drurnbo.com>
To	"Rafaiel@Drumbo.com" <Rafaiel@Drumbo.com>
Subject	Immediate Action Required: Your Employment Contract.

P2: El ransomware se identificó como parte de una familia de malware conocida. Determinar su nombre de familia puede proporcionar información crucial sobre su comportamiento y las estrategias de remediación.

¿Cuál es el nombre de familia del ransomware identificado durante la investigación?

R: badrabbit

Se analizó el archivo EML con VirusTotal y los motores de antivirus calificaron el malware con la etiqueta de familia “badrabbit”.

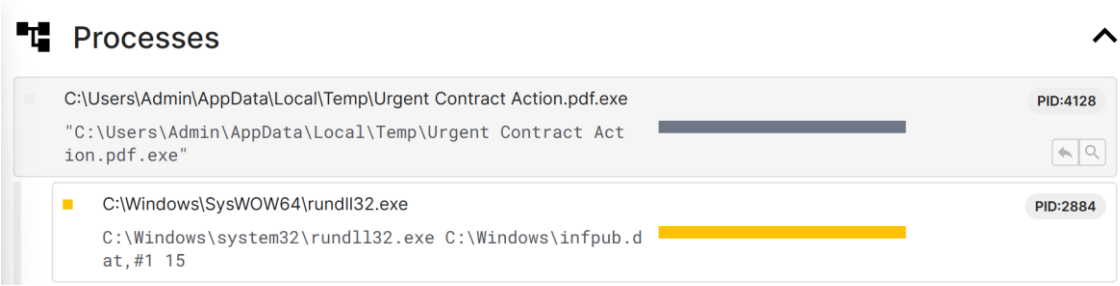


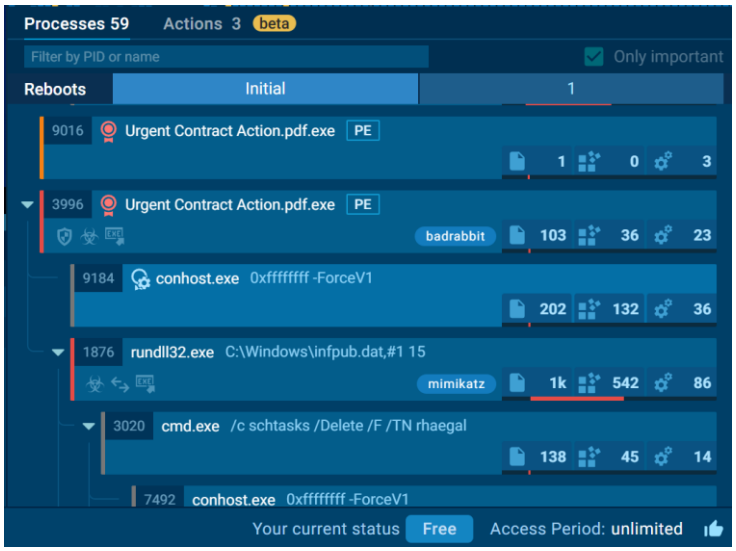
P3: Tras su ejecución, el ransomware ingresó un archivo en el sistema comprometido para iniciar su carga útil. Identificar este archivo es esencial para comprender su proceso de infección.

¿Cómo se llama el primer archivo que descargó el ransomware?

R: infpub.dat

Al analizar los reportes de análisis dinámico en herramientas como Any.run o Tria.ge se puede hallar en el árbol de procesos que el primer archivo que descargó el ransomware al sistema fue infpub.dat.





P4: Dentro del archivo descargado, el malware contenía artefactos codificados, incluyendo nombres de usuario y contraseñas que podrían proporcionar pistas sobre su origen o configuración.

¿Cuál es el único nombre de usuario encontrado en el archivo descargado?

R: alex

Luego del análisis del reporte proporcionado por Any.run se descargó el archivo infpub.dat. Se realizó ingeniería inversa del archivo con la herramienta IDA y se determinó que el usuario fue alex.

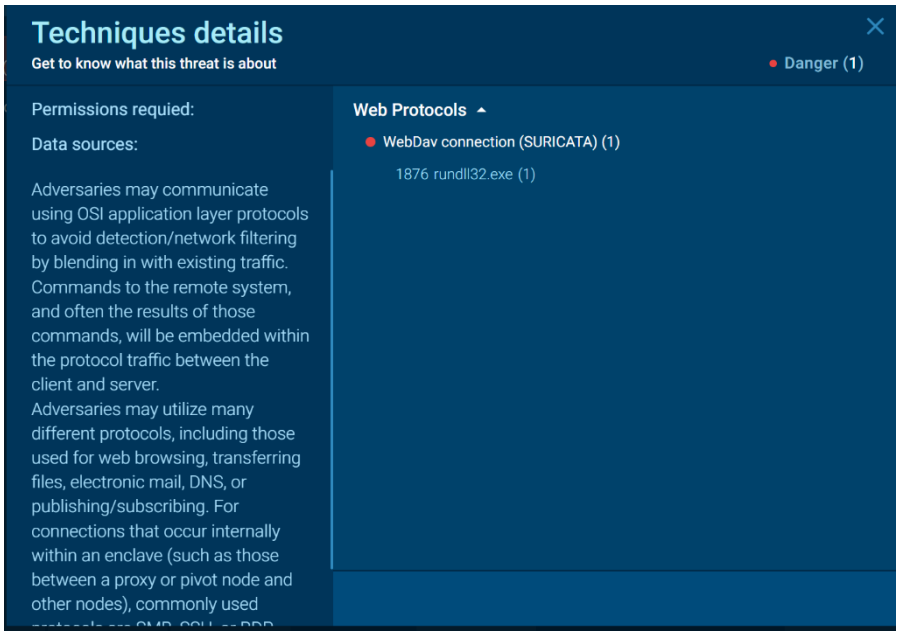
```
.rdata:100107AA                 align 4
.rdata:100107AC aGuest:                                 ; DATA XREF: .data:10013500↓o
.rdata:100107AC                 text "UTF-16LE", 'guest',0
.rdata:100107B8 aAdministrator_0:                       ; DATA XREF: .data:100134F8↓o
.rdata:100107B8                 text "UTF-16LE", 'administrator',0
.rdata:100107D4 aAlex:                                  ; DATA XREF: .data:100134E8↓o
.rdata:100107D4                 text "UTF-16LE", 'alex',0
.rdata:100107DE                 align 10h
.rdata:100107E0 aNetguest:                              ; DATA XREF: .data:100134E4↓o
.rdata:100107E0                 text "UTF-16LE", 'netguest',0
.rdata:100107F2                 align 4
.rdata:100107F4 aSuperuser:                             ; DATA XREF: .data:100134E0↓o
```

P5: Tras su ejecución, el ransomware se comunicó con un servidor C2. Reconocer sus técnicas de comunicación puede ayudar a mitigar el ataque.

¿Qué subtécnica de MITRE ATT&CK describe el uso de protocolos web por parte del ransomware para enviar y recibir datos?

R: T1071.001

Tras la ejecución, el ransomware se comunicó con un servidor C2. Este comportamiento está mapeado en la matriz MITRE ATT&CK con la táctica C & C. La subtécnica es Web Protocols con ID T1071.001. Esta subtécnica consiste en el uso de protocolos de capa de aplicación OSI para evitar la detección o el filtrado de red.

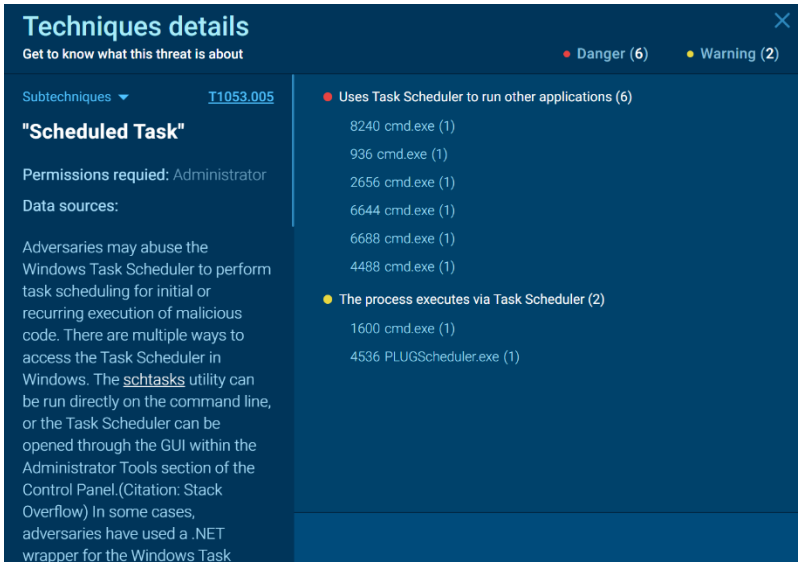


P6: Los mecanismos de persistencia son un sello distintivo del ransomware sofisticado. Identificar cómo se logró la persistencia puede facilitar la recuperación y la prevención de reinfecciones.

¿Cuál es el ID de la subtécnica MITRE ATT&CK asociado con la técnica de persistencia del ransomware?

R: T1053.005

El ransomware usó el programador de tareas de Windows y la utilidad schtasks para ejecutar directamente comandos en el cmd y garantizar su persistencia. Este comportamiento está mapeado en MITRE ATT&CK con la subtécnica Scheduled Task de ID T1053.005.



P7: Como parte de su cadena de infección, el ransomware creó tareas específicas para garantizar su funcionamiento continuo. Reconocer estas tareas es crucial para la restauración del sistema. ¿Cómo se llaman las tareas creadas por el ransomware durante su ejecución?

R: rhaegal, drogon

Para garantizar su persistencia el ransomware ejecuta líneas de comandos preprogramadas.

La primera línea de comandos nombrada rhaegal se inicia creando la tarea programada con schtasks donde establece el uso de ONSTART para que la tarea se ejecute automáticamente cada vez que el sistema se reinicie. Esta tarea se ejecutará bajo la cuenta SYSTEM.

```
Image:      C:\Windows\SysWOW64\schtasks.exe
Cmdline:    schtasks /Create /RU SYSTEM /SC ONSTART /TN rhaegal /TR
            "C:\WINDOWS\system32\cmd.exe /C Start \"\" \"C:\Windows
            \dispci.exe\" -id 1238445670 && exit"
```

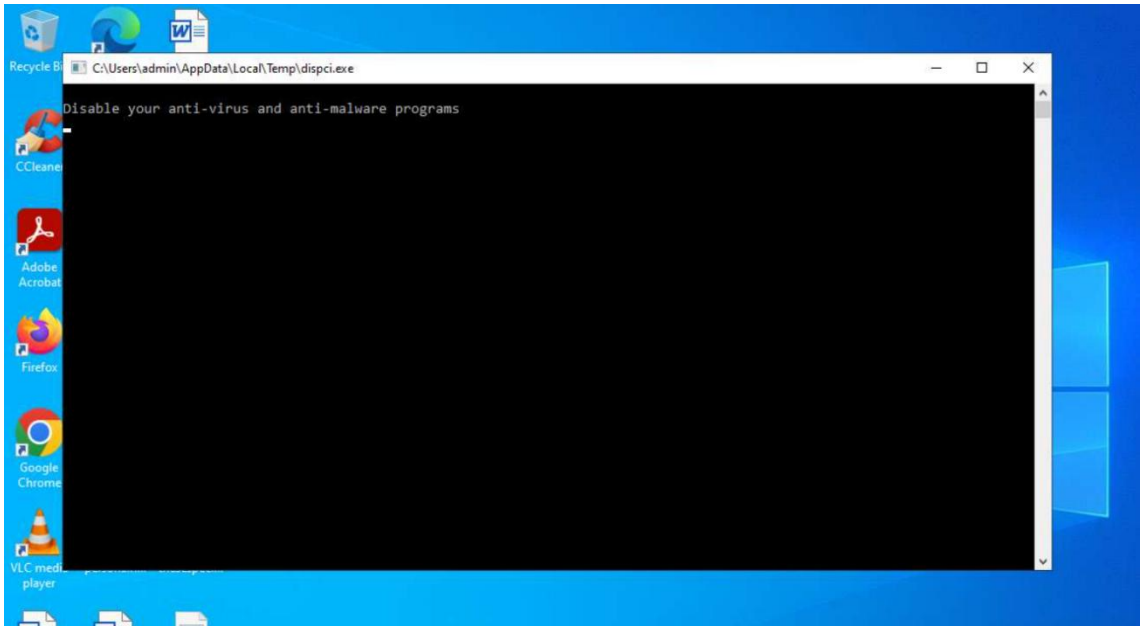
La segunda línea de comandos nombrada drogon se inicia creando la tarea programada con schtasks donde se indica que será de un solo uso y se establecerá la hora de ejecución a las 10:06:00 horas. Esta tarea se ejecutará con privilegios SYSTEM y tendrá como finalidad el reinicio forzoso del sistema al llamar al ejecutable de Windows shutdown.exe. Como resultado, luego del reinicio, el sistema ya habrá sido infectado mostrando solamente la pantalla de rescate.

```
Image:      C:\Windows\SysWOW64\schtasks.exe
Cmdline:    schtasks /Create /SC once /TN drogon /RU SYSTEM /TR "C:\W
            INDOWS\system32\shutdown.exe /r /t 0 /f" /ST 10:06:00
```

P8: El binario malicioso dispci.exe mostraba un mensaje sospechoso al ejecutarse, instando a los usuarios a desactivar sus defensas. Esta táctica buscaba evadir la detección y permitir la ejecución completa del ransomware. ¿Qué mensaje sospechoso se mostró en la consola al ejecutar este binario?

R: Disable your anti-virus and anti-malware programs

Se realizó el análisis dinámico del archivo dispci.exe en Any.run para visualizar su comportamiento. En cuanto se ejecuta se muestra el mensaje “Disable your anti-virus and anti-malware programs”.

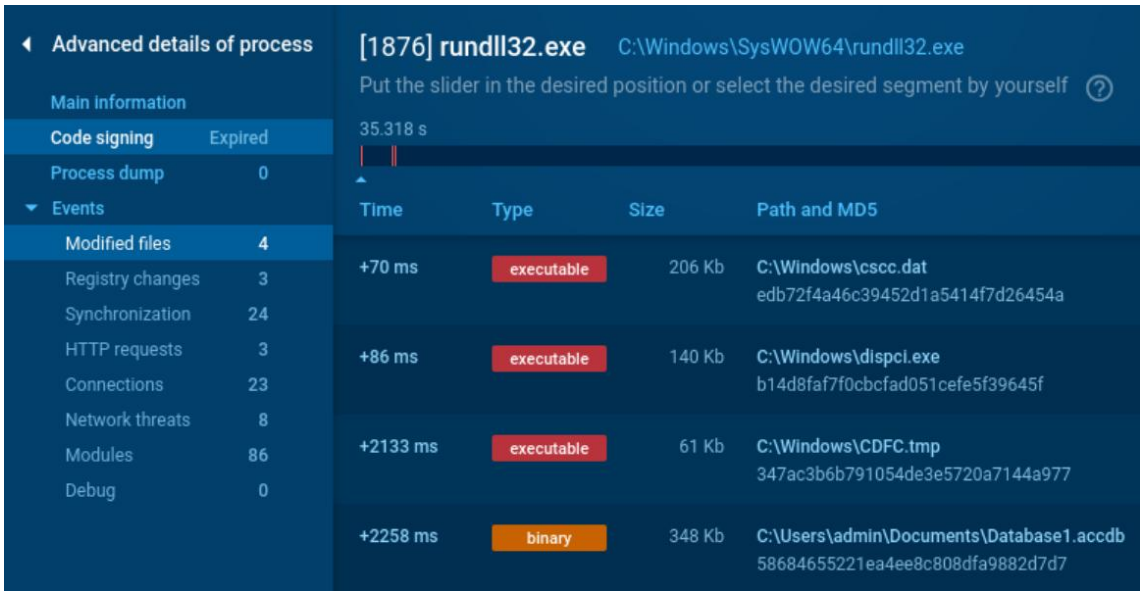


P9: Para modificar el Registro de Arranque Maestro (MBR) y cifrar el disco duro de la víctima, el ransomware utilizó un controlador específico. Reconocer este controlador es esencial para comprender el mecanismo de cifrado.

¿Cómo se llama el controlador utilizado para cifrar el disco duro y modificar el MBR?

R: DiskCryptor

El ransomware (rundll32.exe) secuestra un driver legítimo cscc.dat para el cifrado de disco duro de la víctima y la modificación del MBR. Este driver está basado en el software de código abierto llamado DiskCryptor (dcrypt.sys).

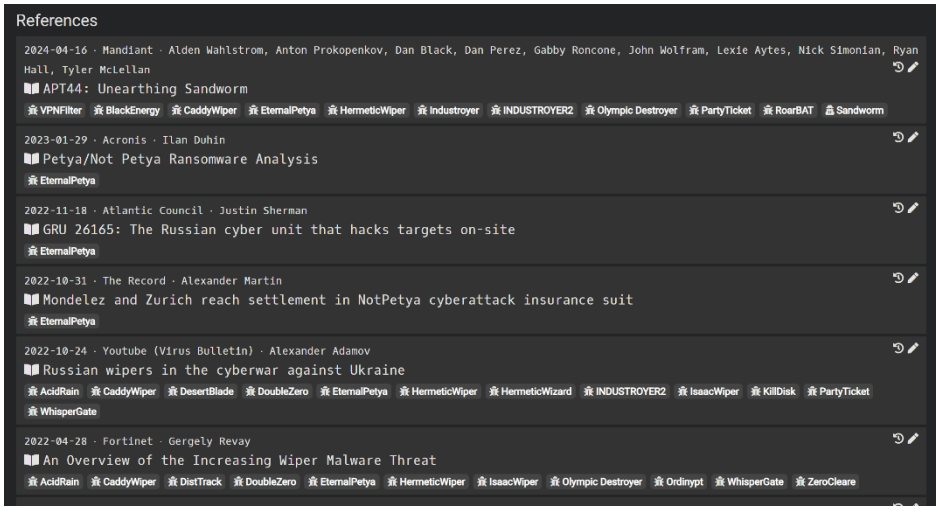


P10: La atribución es clave para comprender el panorama de amenazas. El ransomware se vinculó a un grupo de ataque conocido mediante sus tácticas, técnicas y procedimientos (TTP).

¿Cuál es el nombre del actor de amenazas responsable de esta campaña de ransomware?

R: Sandworm

Según investigaciones forenses digitales reportadas en Malpedia, se le atribuyó la responsabilidad del ransomware BadRabbit al grupo de ataque Sandworm, perteneciente a las fuerzas militares de Rusia. Esta atribución generó controversias debido a que el ransomware afectó en gran medida a Rusia. Sin embargo, el indicador determinante fue la coincidencia de infraestructura y código compartida con el ransomware NotPetya.



P11: El ransomware impidió el arranque del sistema al corromper componentes críticos. Identificar la técnica utilizada proporciona información sobre su capacidad destructiva.

¿Cuál es el ID de MITRE ATT&CK de la técnica utilizada para corromper el firmware del sistema e impedir el arranque?

R: T1495

BadRabbit utiliza un ejecutable que instala un gestor de arranque modificado para evitar el arranque normal. Esta técnica esta mapeada en MITRE ATT&CK con el ID T1495, Firmware Corruption.